

Application Security Assessment

Engagement PT-2026-76 | Tester L. Petrov | Scope: Identity provider and single sign-on. This is a manual penetration-test report: it documents exploited attack paths and prioritized recommendations, not an automated scan summary.

ENGAGEMENT ID	TEST TYPE
PT-2026-76	Grey-box
START DATE	END DATE
2026-06-17	2026-06-26
OVERALL RISK	FINDINGS
High	11

EXPLOITED ATTACK PATHS

#	Attack path	Impact	Related CVE
1	Forged SSO assertion → admin console	Critical	CVE-2026-10022
2	Injected report filter → data read	High	CVE-2025-48291
3	Routing header → gateway RCE	Critical	CVE-2026-31847

Each path was validated in a controlled window with the blue team notified. No production data was exfiltrated; proof-of-concept access was demonstrated and then revoked.

PRIORITIZED RECOMMENDATIONS

1. Enforce signature validation on inbound SSO assertions and rotate broker signing keys. 2. Parameterize the reporting filter and constrain the connector's database role. 3. Patch the gateway routing filter and add a WAF rule for the crafted header. 4. Add detection for anomalous administrative logins.

RETEST

A retest is recommended within 30 days of remediation to confirm each exploited path is closed. Findings map to per-CVE advisories where a CVE identifier applies; process and configuration findings do not carry a CVE.